



Vulnerability Assessment Report for a Live Website

Vulnerability Assessment Report of a public website (Read-only security analysis).

Table of Contents

1. Title & Introduction	3
2. Scope & Attributes	4
3. Risk Classification	5
4. Summary of Identified Vulnerabilities	6
5. Detailed Technical Information	8
6. Appendix	19



1. TITLE & INTRODUCTION

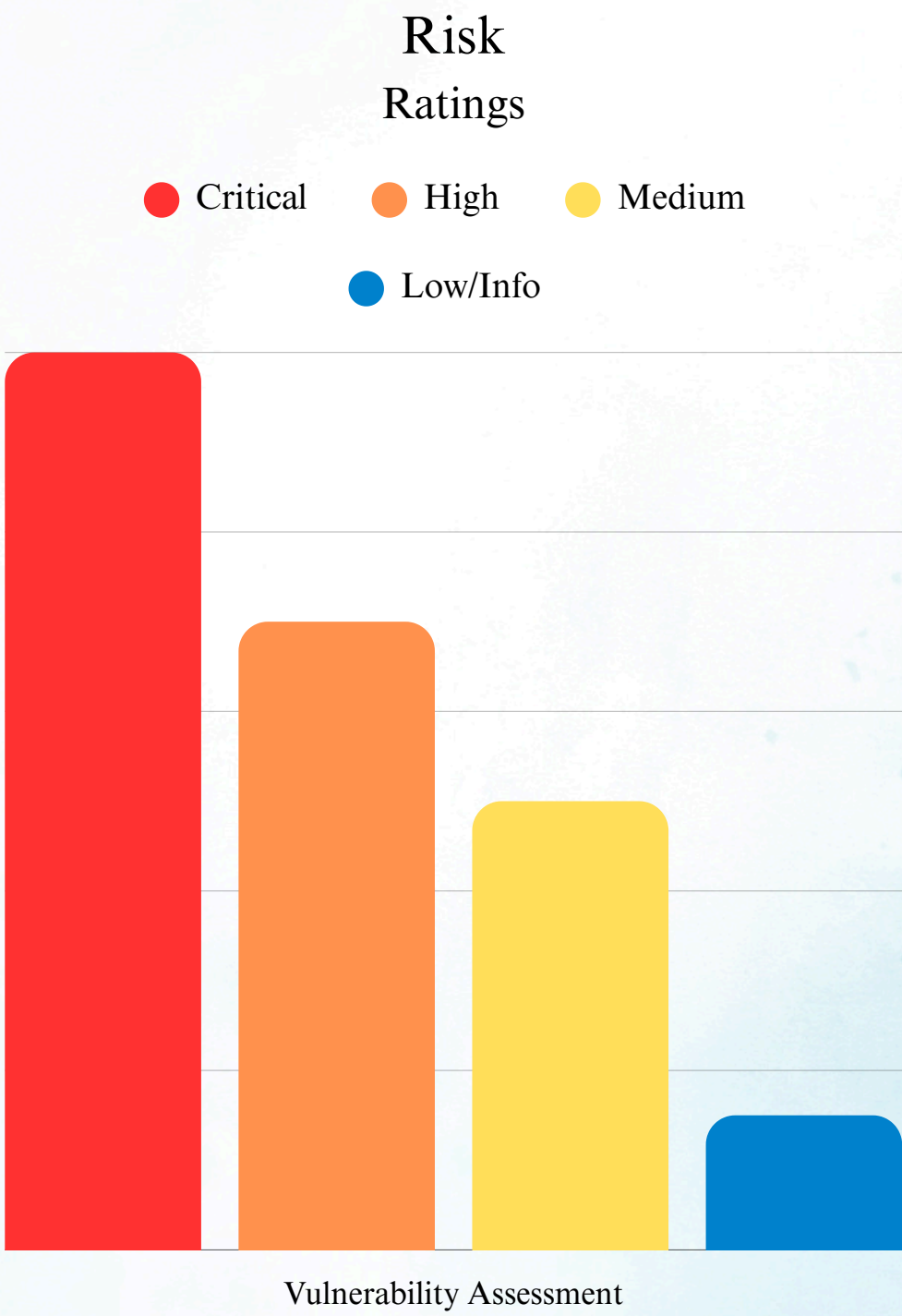
- **Report Title:** Vulnerability Assessment Report for a Live Website
- **Project Name:** Zero Bank Security Assessment
- **Prepared By:** Mohana Priya
- **Executive Summary:** This document describes the proceedings and results of a security assessment conducted against the Zero Bank web application. The assessment utilized automated scanning and manual inspection to uncover 12 distinct vulnerabilities. These findings range from high-risk encryption weaknesses to medium-risk injection possibilities and informational data leaks.

2. SCOPE & ATTRIBUTES

- **Application Name:** Zero Bank
- **Target URL:** <http://zero.webappsecurity.com>
- **IP Address:** 54.82.22.214
- **Assessment Attributes:**
 - ➔ **Starting Vector:** External
 - ➔ **Target Criticality:** High (Financial Site)
 - ➔ **Nature:** Cautious & Calculated
 - ➔ **Proof of Concept:** Attached where applicable.

3. RISK CLASSIFICATION

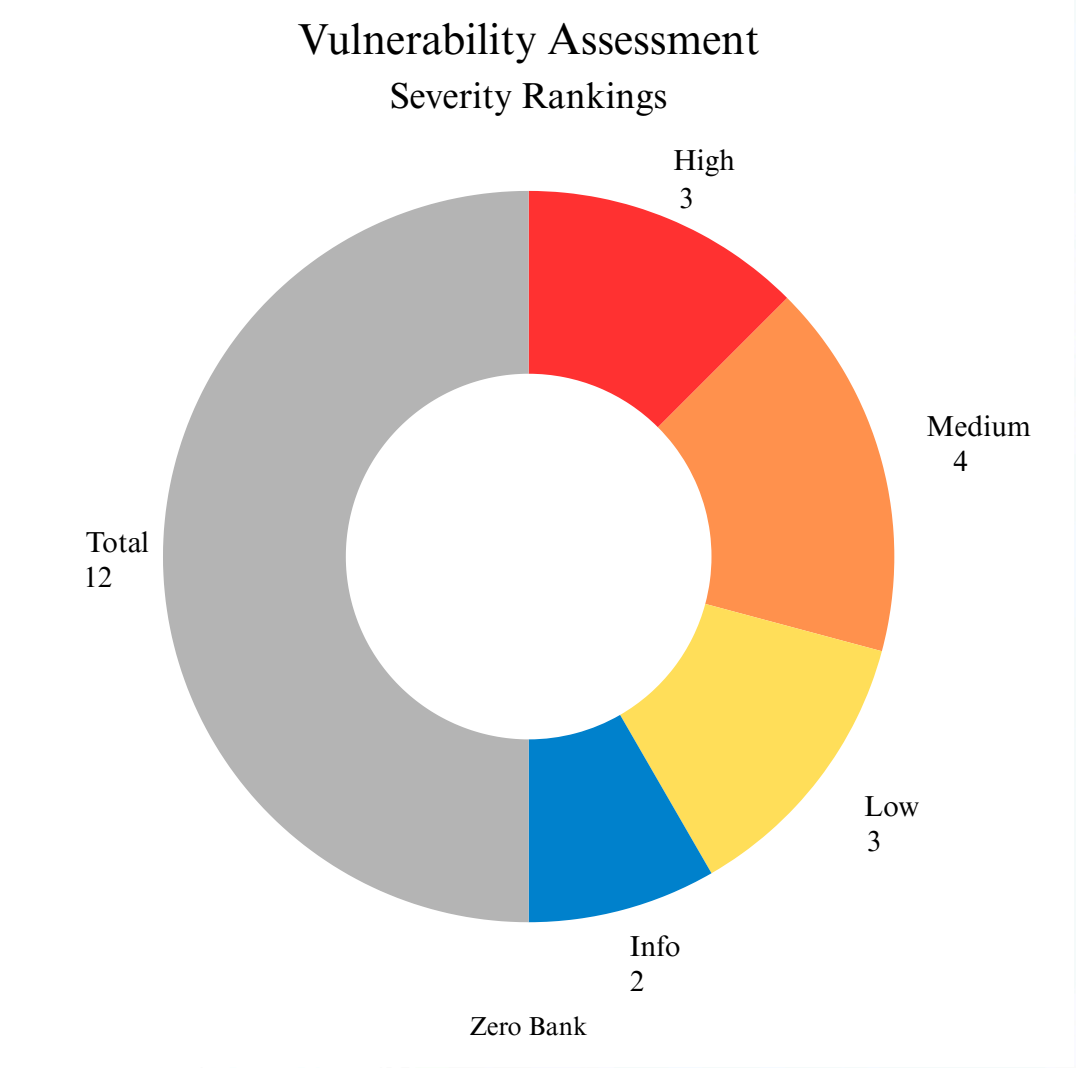
Severity Ratings	Explanation
Critical	Exploitable publicly. No fix available from vendor.
High	Exploitable publicly. Fix/patch available.
Medium	No public exploit yet. Patch/workaround not yet released.
Low/Info	No direct threat. Reveals sensitive information or has available workarounds.



4. SUMMARY OF IDENTIFIED VULNERABILITIES

Severity	Count	Findings
High	3	SQL Injection (SQLite), SSL/TLS MITM (CCS Injection), DHE_EXPORT Downgrade (Logjam)
Medium	4	Cross-Site Request Forgery (CSRF), Missing CSP Header, Cross-Domain Misconfiguration, Vulnerable JS Library
Low	3	Missing Anti-clickjacking Header, Server Version Information Leak, X-Content-Type-Options Header Missing
Info	2	Suspicious Comments in Code, Modern Web Application structure
Total	12	Unique Vulnerabilities Found

RISK CATEGORISATION



Detailed Comparison of Results

1. High Risk

- SQL Injection - SQLite
- SSL/TLS MITM (CCS Injection)
- DHE_EXPORT Downgrade (Logjam)

2. Medium Risk

- Cross-Site Request Forgery (CSRF)
- Missing CSP Header
- Cross-Domain Misconfiguration
- Vulnerable JS Library

3. Low Risk

- Missing Anti-clickjacking Header
- Server Information Leak
- X-Content-Type-Options Missing

4. Informational

- Suspicious Comments
- Modern Web Application

5. DETAILED TECHNICAL INFORMATION

(VULN_01)

- **Vulnerability Name:** **SQL Injection** (SQLite)
- **Reference ID:** VULN_01
- **Risk Rating:** **High**
- **Tools Used:** OWASP ZAP
- **CWE ID:** 89
- **Vulnerability Description:** A potential SQL injection was identified in the fontawesome-webfont.woff parameter.
- **Vulnerable URL/IP:**
<http://zero.webappsecurity.com/static/fonts/fontawesome-webfont.woff?v=4.0.3>
- **Implications:** Attackers could manipulate database queries to extract sensitive user data or bypass authentication.
- **Suggested Countermeasures:** Use parameterized queries and sanitize all user-supplied input.
- **References:** OWASP SQL Injection Guide

DETAILED TECHNICAL INFORMATION

(VULN_02)

- **Vulnerability Name:** **SSL/TLS MITM** (CCS Injection)
- **Reference ID:** VULN_02
- **Risk Rating:** **High**
- **Tools Used:** Nmap (ssl-ccs-injection)
- **CVE ID:** CVE-2014-0224
- **Vulnerability Description:** The host is vulnerable to a Man-In-The-Middle attack due to improper ChangeCipherSpec handling.
- **Vulnerable URL/IP:** **54.82.22.214:443**
- **Implications:** Attackers can intercept and decrypt encrypted traffic between the user and the server.
- **Suggested Countermeasures:** Update OpenSSL to a patched version (CVE-2014-0224).
- **References:** NVD CVE-2014-0224

DETAILED TECHNICAL INFORMATION

(VULN_03)

- **Vulnerability Name:** **DHE_EXPORT Downgrade**
(Logjam)
- **Reference ID:** VULN_03
- **Risk Rating:** **High**
- **Tools Used:** Nmap (ssl-dh-params)
- **CVE ID:** CVE-2015-4000
- **Vulnerability Description:** The server supports weak 512-bit export-grade Diffie-Hellman parameters.
- **Vulnerable URL/IP:** [54.82.22.214:443](#)
- **Implications:** Encryption can be broken by a MITM attacker, exposing session data.
- **Suggested Countermeasures:** Disable export-grade ciphers and use 2048-bit DH primes.
- **References:** [WeakDH.org](#)

DETAILED TECHNICAL INFORMATION

(VULN_05)

- **Vulnerability Name:** **Missing Content Security Policy (CSP) Header**
- **Reference ID:** VULN_05
- **Risk Rating:** **Medium**
- **Tools Used:** OWASP ZAP
- **CWE ID:** 693
- **Vulnerability Description:** No CSP header is defined to restrict resource loading.
- **Vulnerable URL/IP:** <http://zero.webappsecurity.com>
- **Implications:** Increased susceptibility to Cross-Site Scripting (XSS) and data injection.
- **Suggested Countermeasures:** Define a strict CSP header in the server configuration.
- **References:** MDN Web Docs: CSP

DETAILED TECHNICAL INFORMATION

(VULN_06)

- **Vulnerability Name:** **Cross-Domain Misconfiguration**
- **Reference ID:** VULN_06
- **Risk Rating:** **Medium**
- **Tools Used:** OWASP ZAP
- **CWE ID:** 264
- **Vulnerability Description:** The application allows resource sharing with untrusted origins.
- **Vulnerable URL/IP:**
<http://zero.webappsecurity.com/login.html>
- **Implications:** Malicious sites can potentially steal session information.
- **Suggested Countermeasures:** Restrict Access-Control-Allow-Origin to trusted domains only.
- **References:** PortSwigger: CORS

DETAILED TECHNICAL INFORMATION

(VULN_07)

- **Vulnerability Name:** **Vulnerable JavaScript Library**
- **Reference ID:** VULN_07
- **Risk Rating:** **Medium**
- **Tools Used:** OWASP ZAP
- **CWE ID:** 1395
- **Vulnerability Description:** The site uses outdated JS libraries with known security flaws.
- **Vulnerable URL/IP:**
<http://zero.webappsecurity.com/static/js/>
- **Implications:** Known exploits could be used to compromise the client-side session.
- **Suggested Countermeasures:** Update all third-party libraries to the latest stable versions.
- **References:** Snyk Advisor

DETAILED TECHNICAL INFORMATION

(VULN_08)

- **Vulnerability Name:** Missing Anti-Clickjacking Header
- **Reference ID:** VULN_08
- **Risk Rating:** Low
- **Tools Used:** OWASP ZAP
- **CWE ID:** 1021
- **Vulnerability Description:** X-Frame-Options allows the site to be framed.
- **Vulnerable URL/IP:** <http://zero.webappsecurity.com>
- **Implications:** Attackers can trick users into clicking hidden buttons via transparency overlays.
- **Suggested Countermeasures:** Set X-Frame-Options to DENY or SAMEORIGIN.
- **References:** OWASP Clickjacking

DETAILED TECHNICAL INFORMATION

(VULN_09)

- **Vulnerability Name:** **Server Version Information Leak**
- **Reference ID:** VULN_09
- **Risk Rating:** **Low**
- **Tools Used:** Nmap (http-server-header)
- **CVE ID:** CVE-2011-3192
- **Vulnerability Description:** Server headers reveal "Apache-Coyote/1.1".
- **Vulnerable URL/IP:** 54.82.22.214:8080
- **Implications:** Attackers can research version-specific exploits.
- **Suggested Countermeasures:** Mask server banners in the Apache/Tomcat configuration.
- **References:** Apache Security Tips

DETAILED TECHNICAL INFORMATION

(VULN_10)

- **Vulnerability Name:** **Missing X-Content-Type-Options Header**
- **Reference ID:** VULN_10
- **Risk Rating:** **Low**
- **Tools Used:** OWASP ZAP / Browser Inspect
- **CWE ID:** 693
- **Vulnerability Description:** The nosniff header is not present.
- **Vulnerable URL/IP:** <http://zero.webappsecurity.com>
- **Implications:** Prevents browsers from MIME-sniffing a response away from the declared content-type.
- **Suggested Countermeasures:** Add X-Content-Type-Options: nosniff header.
- **References:** Checkmarx: Missing Headers

DETAILED TECHNICAL INFORMATION

(VULN_11)

- **Vulnerability Name:** Suspicious Comments in Code
- **Reference ID:** VULN_11
- **Risk Rating:** Info
- **Tools Used:** OWASP ZAP / Browser Inspect
- **CWE ID:** 615
- **Vulnerability Description:** Informational comments left in the HTML source.
- **Vulnerable URL/IP:**
<http://zero.webappsecurity.com/index.html>
- **Implications:** May reveal internal logic or developer notes to an attacker.
- **Suggested Countermeasures:** Remove comments before deploying to production.
- **References:** CWE-615

DETAILED TECHNICAL INFORMATION

(VULN_12)

- **Vulnerability Name:** **Directory Enumeration**
- **Reference ID:** VULN_12
- **Risk Rating:** **Info**
- **Tools Used:** Nmap (http-enum)
- **Vulnerability Description:** Discovery of folders like /admin/ and /README.txt.
- **Vulnerable URL/IP:**
<http://zero.webappsecurity.com:8080/>
- **Implications:** Helps attackers map the server's file structure.
- **Suggested Countermeasures:** Disable directory listing and restrict access to admin folders.
- **References:** OWASP Info Leakage

6. APPENDIX

- Heading: Visual Evidence
- Content:

Fig 1: Screenshot of ZAP Alert Tree showing the SQL Injection and Header alerts.

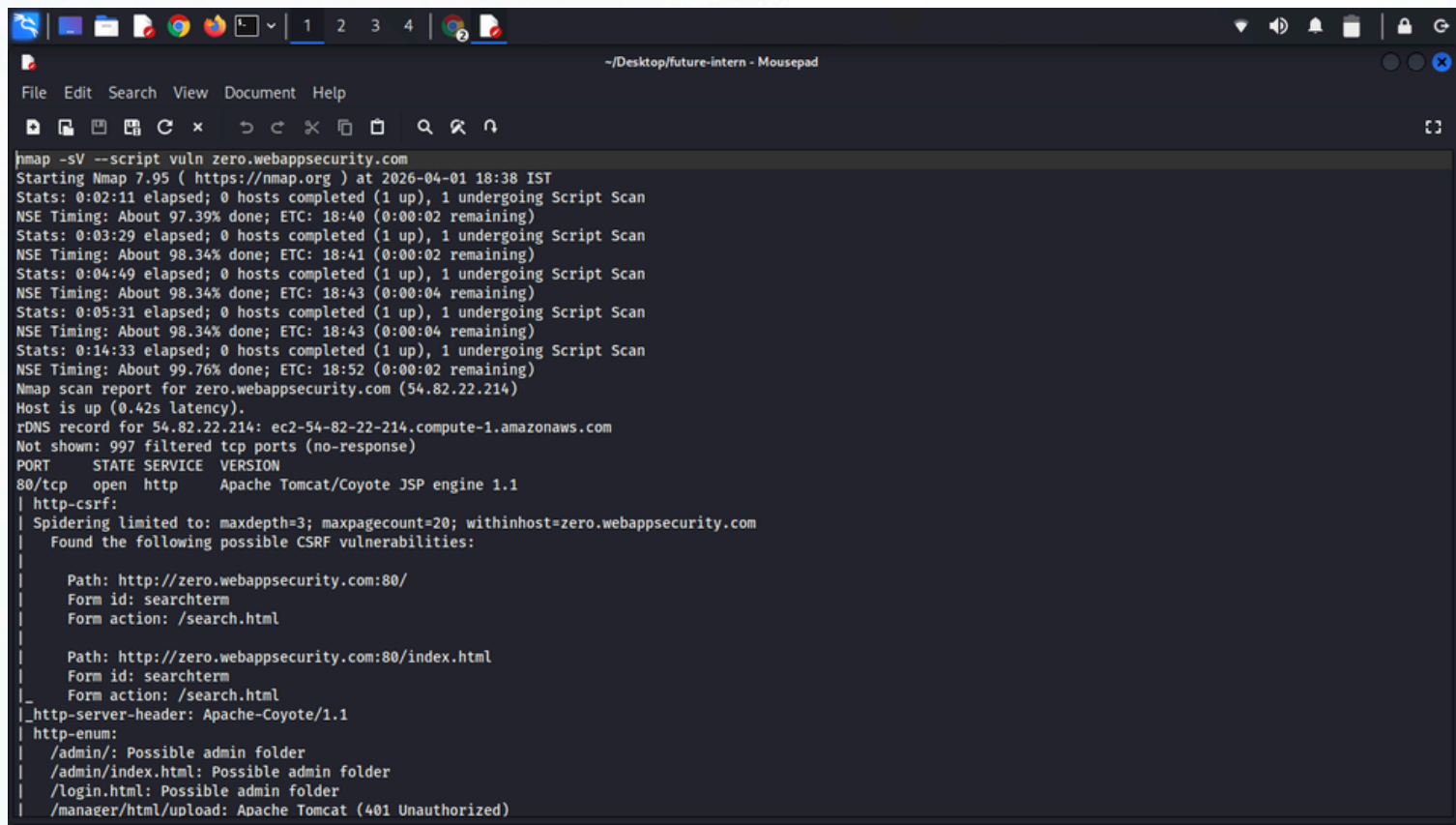
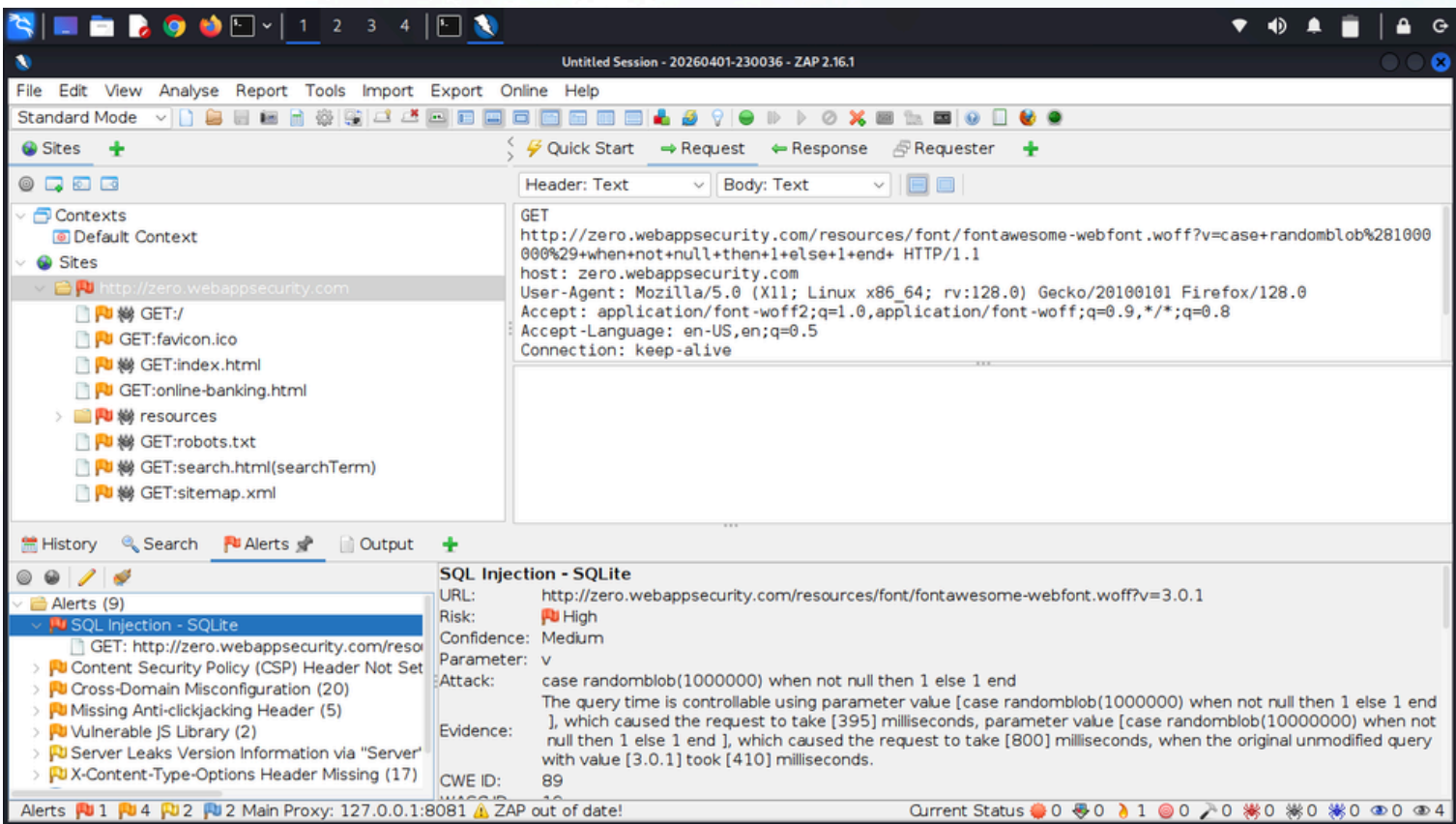


Fig 2: Nmap scan terminal output showing the SSL-CCS-Injection and Logjam results.

PROOF OF CONCEPT (POC).

- Heading: Visual Evidence
- Content:

Fig 3: Screenshot of ZAP Report Contents showing the Results

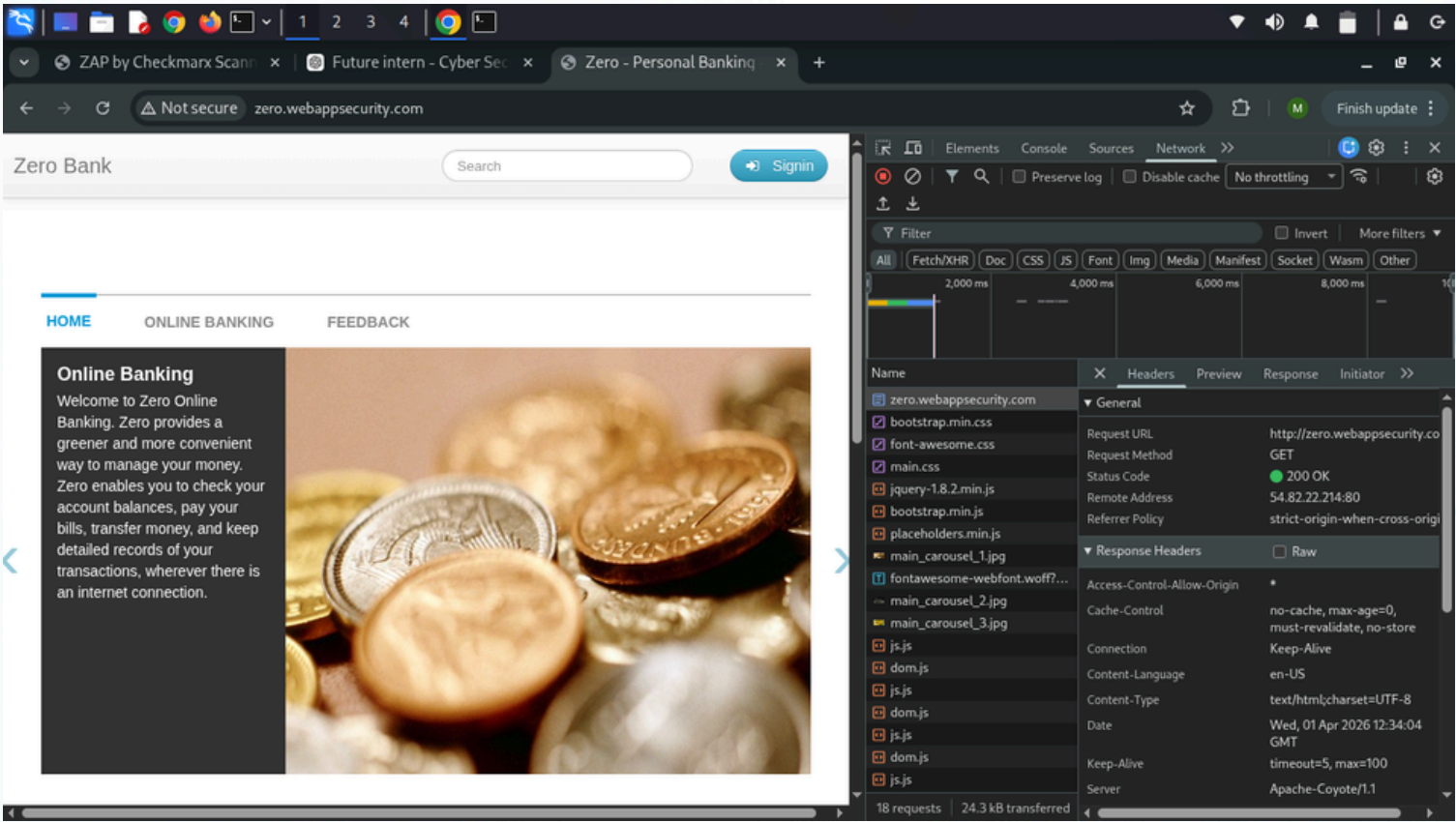
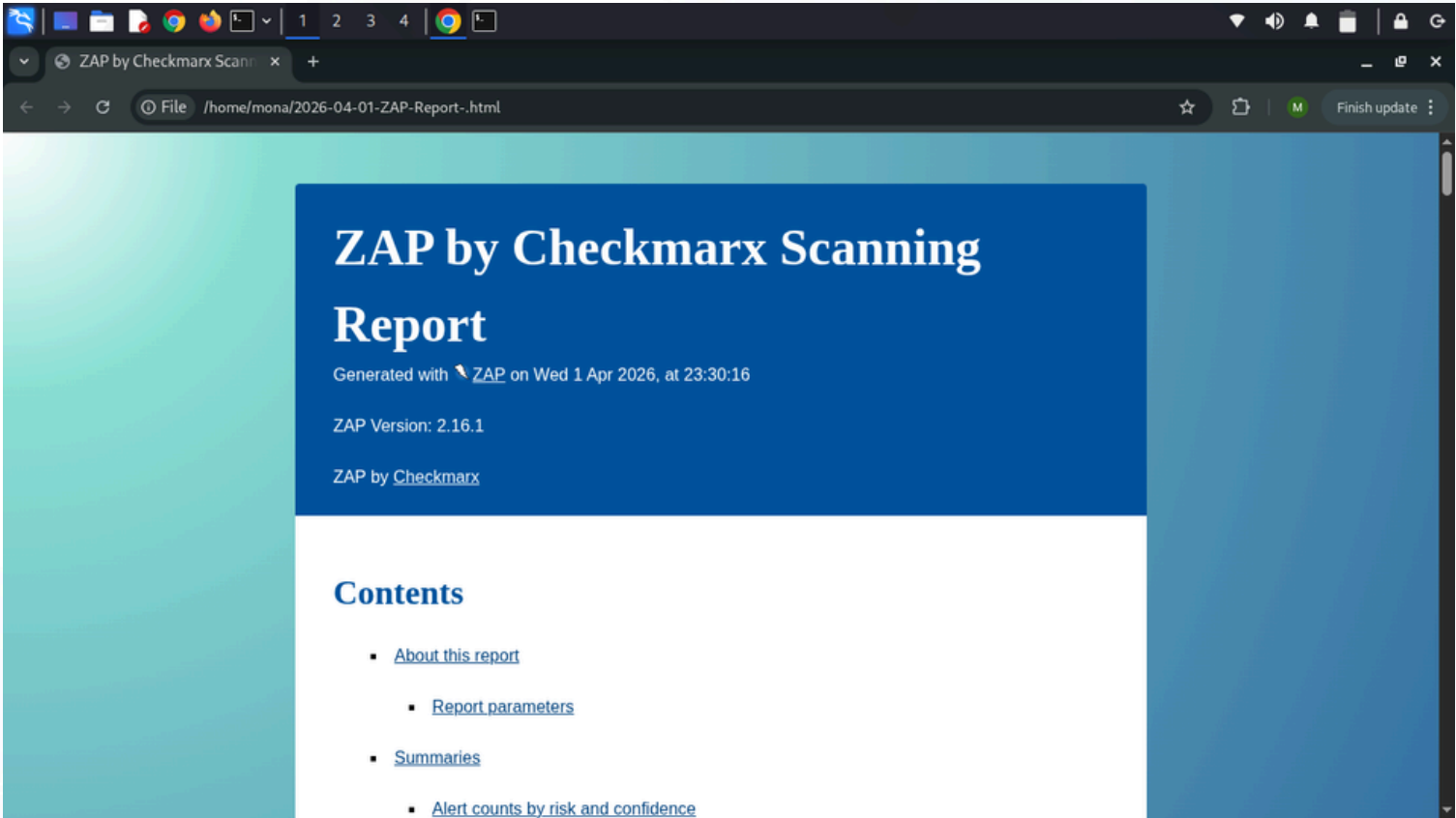


Fig 4: Browser Inspect (Network Tab) showing the absence of X-Frame-Options and CSP in the headers.



“

A vulnerability is not a failure, but a opportunity—turning hidden backdoors into fortified strengths before they are discovered by the hackers.”

”

Mohana Priya

Thank You for your solely reading